

Country Flag

[insert flag image]

Booth Number

after qualification



Source code, benchmark and documentation

Introduction

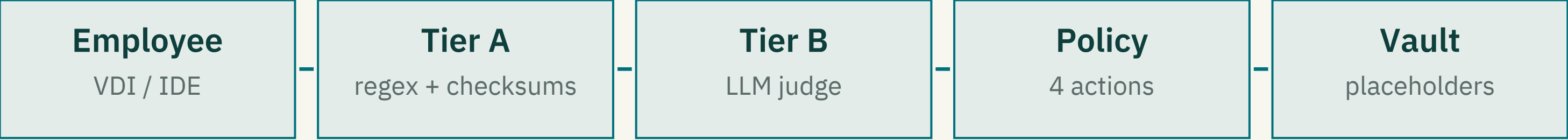
Organizations want their people using Claude, ChatGPT and Copilot. Security teams cannot allow it, because a prompt is an unlogged, unclassified, free-text egress channel straight out of the perimeter.

- Block everything and you get shadow AI on personal devices - zero visibility, worse leakage.
- Allow everything and customer PII, source code and undisclosed deals leave with no record.
- Classic DLP was built for files and email. It cannot judge a sentence such as "our unreleased platform has an auth bypass" - no pattern matches it, yet it is the most damaging thing an employee could paste.

In Saudi Arabia the PDPL and NCA controls make cross-border transfer of personal data a legal question, not a preference - so where the inspection itself runs matters as much as what it detects.

Methodology

A gateway in the egress path inspects every outbound prompt and file before it leaves the tenant.



- Tier A - deterministic. Saudi national ID and Iqama (Luhn check digit), IBAN (mod-97), payment cards, provider API keys, private keys, connection strings, internal hosts, and the organization's own codename watchlist. Sub-millisecond; it carries most traffic.
- Tier B - semantic. An LLM judge runs only when there is prose long enough to hide meaning a pattern cannot see. It returns spans, classes, confidence and a rationale under a strict schema; its input is wrapped as untrusted data, and every span it reports is located in the text by the gateway, so hallucinated spans are discarded.
- Policy engine - allow, pseudonymize, escalate to a human, or block; per-group overrides in one readable YAML file.
- Token vault - session-stable placeholders, AES-256-GCM, never leaving the tenant. A hash-chained audit log records classes and decisions, never the values it protected.

Results

Measured over a 33-prompt labeled corpus (15 deliberately benign), three consecutive runs, 99 judge calls.

	Tier A	Tier B
Precision	100.0%	91.7%
Recall	100.0%	100.0%
False alarms on 15 clean prompts	0	0
Median latency	0.12 ms	1.4 s
Degraded / failed calls	-	0 of 99

- Combined across both tiers: precision 96.6%, recall 93.3%, F1 94.9%.
- Stability: 30 of 30 expectations were found in every run, with identical findings each time - a control that catches a different subset each run is unusable for audit even at a good average rate.
- Tier B recall is span-level. The gap to strict-class recall is category disagreement, not missed data, and every such error resolved toward human review rather than under-protection.

Stated plainly: this corpus is small and hand-built. It is a regression harness and a starting point for evaluation, not a claim about production accuracy.

Innovation

Every product in this space masks. Masking destroys the answer, so people route around the tool. This one substitutes reversibly.

Employee types:

"Customer Ahmed Al-Otaibi (ID 1098765439) reports that Project Falcon fails auth on login."

Model receives:

"Customer PERSON_1 (ID ID_1) reports that PROJECT_1 fails auth on login."

Employee sees: the full answer, with every real value restored - including mid-stream.

- Reversible pseudonymization. One value keeps one placeholder for a whole session, so multi-turn conversations stay coherent and the mapping never leaves the tenant.
- Context-dependent sensitivity. The same facility name is substituted beside a redundancy figure and ignored in a first-aid invitation - a matched pair in the corpus. Sensitivity belongs to the combination, not the word.
- Data residency by design. The judge is pluggable and runs on the organization's own hardware for PDPL compliance. The gateway verifies this itself and labels any judge on a public host as a stand-in rather than flattering the deployment.
- Human-in-the-loop where it matters. Low-confidence findings, and spans too broad to substitute safely, are held for a reviewer rather than acted on silently.

Conclusion

- A working functional prototype shows that enterprises do not have to choose between using frontier AI and protecting what they know. Productivity and protection can be decoupled.
- The deterministic tier carries most traffic at 0.12 ms and never varies; the semantic tier is reserved for the leakage no pattern can see. That split is what makes an inline AI control viable at all.
- Zero false alarms across 15 clean prompts is the number that decides adoption. A control that cries wolf on ordinary work is removed within a week.
- Classification errors resolved toward human review rather than under-protection - for a security control, the correct direction to be wrong.

Future Work & References

- TLS-inspecting interception so browser-based AI tools are covered, not only API traffic.
- A two-stage semantic tier: a small fast classifier gates the expensive span extractor, cutting the latency most prompts pay.
- On-premises judge benchmarking, and coverage for PDF, DOCX and images via OCR.
- Enterprise integration: SIEM connectors, SSO and RBAC, GPO/PAC deployment.
- A larger evaluation corpus written independently of the detector, to replace the hand-built harness.

References

Saudi Personal Data Protection Law (PDPL), SDAIA. | NCA Essential Cybersecurity Controls (ECC-1:2018). | OWASP Top 10 for Large Language Model Applications. | ISO 13616 (IBAN) and ISO/IEC 7812 (Luhn) checksum standards. | Full source, benchmark corpus and reproducible results: github.com/OsamaQh4/hajiz-dlp-gateway

Acknowledgments Statement

Independently developed and self-funded, with no institutional, laboratory, or commercial sponsorship. With the prototype complete and independently validated, the author welcomes research partners, pilot deployment sites, and sponsorship to carry it to production readiness.